

Case 003 — DBS/POSB Digital Token Phishing

1. Case Summary

- **Case ID:** case-003
- **Classification:** Phishing / Credential-Theft Attempt
- **Severity:** High
- **Confidence:** High
- **Subject:** Account Notice: Digital Token Update Needed
- **From:** "DBS/POSB." <noreply@substackss.firebaseio.com>
- **Reply-To:** None
- **Date:** 12 Feb 2026 05:15:59 +0000

The email impersonates DBS/POSB and claims that the recipient's digital banking authentication token is no longer valid. It urges the recipient to update the token through a prominent button. The visible sender uses a Firebase-hosted subdomain rather than an official DBS/POSB domain, and the update button uses `email.notify.thinkific.com` as redirect infrastructure.

2. Header and Authentication Analysis

SPF

Result: PASS

The receiving system reports:

```
spf=pass (sender IP is 209.85.222.71) smtp.mailfrom=substackss.firebaseio.com
```

This indicates that the sending infrastructure was authorized for the envelope sender domain. SPF pass does not establish that DBS/POSB sent the message.

DKIM

Result: PASS

The message contains a valid DKIM signature:

- **Signing domain:** firebaseapp.com
- **Selector:** 20230601

The receiving system reports that the signature was verified.

This authenticates the message to the signing domain, not to DBS/POSB.

DMARC

Result: PERMERROR

The authentication result reports:

```
dmARC=permerror action=none header.from=substackss.firebaseio.com
```

This is a DMARC processing error, not a normal DMARC fail result. It should not be described as proof of spoofing.

Microsoft Composite Authentication

Result: PASS

compauth=pass reason=111

This is a receiving-system composite authentication assessment. It does not establish that the sender is an authorized DBS/POSB representative.

3. Sender Identity Analysis

The visible sender is:

noreply@substackss.firebaseio.com

The message claims to be from DBS/POSB, but the sender domain is a Firebase-hosted subdomain and does not correspond to an official DBS/POSB sender domain.

DNS resolution observed during investigation:

- substackss.firebaseio.com
- IPv4: 199.36.158.100
- IPv6: 2620:0:890::100

These are legitimate shared hosting infrastructure. The IP addresses themselves are not classified as malicious.

The important finding is the mismatch between the claimed financial institution and the authenticated sending infrastructure.

4. Content and Social-Engineering Analysis

The email claims that the recipient's DBS/POSB digital authentication token is invalid and warns that online banking and card-related transactions may be affected.

The message then instructs the recipient to:

"Update Your DBS Digital Token"

This creates a security-related pretext and encourages an immediate account-related action.

Relevant social-engineering indicators:

- Financial-institution impersonation
- Security/authentication pretext
- Potential urgency through claimed service disruption
- Prominent account-update call to action
- Use of official DBS/POSB branding and language
- External redirect infrastructure for the update action

5. HTML and URL Analysis

The plain-text body contained no visible URL, but the email is a multipart/alternative message and its HTML part contains the actual links.

The DBS-branded update button points to:

`hxxps://email[.]notify[.]thinkific[.]com/c/<tracking-token>`

The destination is not a DBS/POSB domain.

The HTML also references a DBS image hosted at:

`hxxps://www[.]dbs[.]com[.]sg/.../brand-left[.]png`

Use of a legitimate DBS image does not authenticate the email; images can be copied into fraudulent messages.

An unsubscribe link points to `hxxps://bing[.]com`, which is not the primary security-update link.

6. Redirect Infrastructure Enrichment

`email.notify.thinkific.com` is associated with legitimate Thinkific infrastructure, but public security reporting has documented phishing campaigns abusing this type of Thinkific email/redirect infrastructure.

This distinction is important:

- Thinkific is legitimate infrastructure.
- The infrastructure's presence does not by itself make a message malicious.
- In this case, the infrastructure is used for a supposed DBS digital-token update, while the visible sender is a Firebase-hosted domain.

The redirect should therefore be treated as a suspicious infrastructure IOC in the context of this message, rather than as proof that the entire service is malicious.

7. IOC Assessment

Domains

IOC	Context	Assessment
<code>substackss.firebaseio.com</code>	Visible sender domain	Suspicious in context; used to impersonate DBS/POSB
<code>firebaseapp.com</code>	DKIM signing domain	Legitimate infrastructure; not inherently malicious
<code>email.notify.thinkific.com</code>	Update-button redirect	Suspicious in context; associated with documented phishing abuse
<code>bing.com</code>	Unsubscribe link	Legitimate domain; not relevant to primary phishing behavior
<code>dbs.com.sg</code>	Embedded image host	Legitimate DBS infrastructure

IP

IOC	Context	Assessment
<code>209.85.222.71</code>	Sending infrastructure	Google-associated/shared infrastructure; not inherently malicious

IOC	Context	Assessment
199.36.158.100	Firebase DNS result	Shared hosting infrastructure; not inherently malicious

Hash artifacts

The extractor identified two SHA-256 values in the headers:

- 25250de3c3297329c7a18bf7cc192cbcd43af44142d5677df8d00ee4db3fc331
- 97c13a581f08deb33051f900c96c95d49a564456d6b4a2eee7aade8c41b85421

These correspond to the email's `OriginalChecksum` and `UpperCasedChecksum` metadata fields. They should **not** be treated as malicious file hashes or payload hashes.

8. MITRE ATT&CK Mapping

T1566 — Phishing

The email uses a fraudulent message to impersonate a financial institution and induce the recipient to take an account-related action.

T1036 — Masquerading

The message presents itself as DBS/POSB through its display name, branding, and banking-related content despite being sent from unrelated infrastructure.

No attachment was identified, so T1566.001 is not applicable.

The message contains a link, but the investigation should describe the observed behavior precisely rather than automatically assigning every link-based phishing message to a sub-technique without confirming the applicable ATT&CK version and technique definition.

9. Investigation Timeline

1. Email received with DBS/POSB branding.
2. Header analysis identified SPF pass and DKIM pass for Firebase infrastructure.
3. DMARC returned permerror.
4. Sender domain identified as `substackss.firebaseio.com`.
5. HTML inspection revealed the digital-token update button.
6. The button was found to use `email.notify.thinkific.com` redirect infrastructure.
7. Sender-domain DNS resolution identified shared Firebase/Google infrastructure.
8. Public security reporting established historical abuse of Thinkific-associated email redirect infrastructure in phishing campaigns.
9. Combined evidence supports classification as a phishing / credential-theft attempt.

10. Risk Assessment

Severity: High

The message impersonates a financial institution and attempts to induce the recipient to perform a digital-token/account-security action. If the destination ultimately collects banking credentials, authentication information, or other sensitive data, successful interaction could result in account compromise or financial fraud.

Confidence: High

Confidence is based on the combination of sender-domain mismatch, financial-institution impersonation, security-token pretext, external redirect infrastructure, and documented abuse of the redirect infrastructure.

11. Analyst Conclusion

Case 003 is assessed as a **phishing / credential-theft attempt impersonating DBS/POSB**.

The strongest evidence is behavioral rather than simply infrastructure reputation. SPF and DKIM authentication succeeded, but they authenticated the message to Firebase-associated infrastructure rather than DBS/POSB. The email then used a prominent digital-token update request and routed the action through `email.notify.thinkific.com`.

Legitimate shared services are involved in the delivery chain, so the associated hosting IPs and parent services should not be independently classified as malicious solely because they appear in this case.

12. Recommended Defensive Actions

- Do not interact with the digital-token update link.
- Report the message to the organization's security or abuse-reporting process.
- If a recipient entered credentials or authentication information, initiate the organization's account-compromise response procedure.
- Monitor for additional messages using the same sender domain, subject pattern, or redirect infrastructure.
- Consider detections for financial-brand impersonation combined with unrelated sender domains and account-security/update language.
- Extend the IOC extractor to inspect decoded HTML MIME parts in future automation work.